

Project Title:

Vendor Risk Assessment – CloudDocs AI

Role Simulated:

GRC Analyst / Third-Party Risk Analyst

Organization:

BrightLife Health Services

Vendor Assessed:

CloudDocs AI (Cloud-Based Document Storage Provider)

Project Overview:

This project simulates a third-party vendor cybersecurity risk assessment conducted to evaluate the security posture of CloudDocs AI, a cloud-based document storage provider. The assessment was performed from the perspective of a Governance, Risk, and Compliance (GRC) analyst responsible for identifying, analyzing, and communicating potential risks associated with engaging an external vendor.

The assessment focused on key cybersecurity and operational risk domains including access control, data protection, incident response, business continuity, logging and monitoring, and third-party (subcontractor) risk management.

Objective:

The objective of this project was to demonstrate practical GRC capabilities by:

- Identifying and evaluating vendor-related cybersecurity risks
- Assessing likelihood and business impact of identified risks
- Determining inherent and residual risk levels

- Providing actionable remediation recommendations
 - Communicating findings through structured reporting and executive summaries
 - Aligning risk assessment activities with recognized industry frameworks
-

Frameworks Referenced:

- NIST Cybersecurity Framework (CSF)
 - ISO/IEC 27001
 - SOC 2 Trust Services Criteria
-

Project Deliverables:

- Vendor Security Questionnaire (control-based assessment)
 - Cybersecurity Risk Register (including likelihood, impact, ownership, and status tracking)
 - Vendor Risk Assessment Report (detailed findings and recommendations)
 - Executive Summary (high-level leadership overview)
 - Remediation Plan with defined timelines
-

Key Risks Identified:

- Incomplete enforcement of multi-factor authentication (MFA)
 - Weak subcontractor (fourth-party) risk management
 - Lack of formal patch management timelines
 - Limited monitoring of suspicious login activity
 - Absence of SOC 2 Type II certification
 - Inadequate disaster recovery testing
-

Outcome:

The vendor received an overall risk rating of Medium to High and was recommended for conditional approval pending remediation of identified risks within defined timelines.

Skills Demonstrated:

- Third-Party Risk Management
- Cybersecurity Risk Assessment
- Risk Register Development and Maintenance
- Governance and Compliance Alignment
- Business Impact Analysis
- Security Control Evaluation
- Executive-Level Communication
- Framework Mapping (NIST CSF, ISO 27001, SOC 2)